

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

Resource 03

Generative AI Security Best Practices

Securing LLM-Powered Tools, Copilots & Agents in the Enterprise

OWASP LLM Top 10 | NIST AI 600-1

Resource ID	TSEC-AI-03
Category	AI Governance
Framework Alignment	OWASP Top 10 for LLM Applications (2025); NIST AI 600-1 Generative AI Profile
Version	1.1
Published	July 2026
Intended Audience	CISOs, Security Engineers, IT Leaders, AI Program Owners
Prepared By	TSEC Risk & Cyber Advisory LLC
Classification	Public — For Educational & Advisory Use

TSEC Compliance Resource Library — www.tsecgrc.com/resources

Table of Contents

- Table of Contents..... 2
- Executive Summary 3
- GenAI Risk Overview 3
- Data Protection 4
 - Classify Before You Connect..... 4
 - Securing RAG Pipelines 4
 - Contain the Blast Radius 4
- Choosing Between Managed and Self-Hosted Models..... 6
- Prompt Security 6
 - Direct vs. Indirect Injection..... 6
 - Secure Prompt Practices 7
- Identity & Access Management..... 7
- Agentic AI Security..... 7
 - Design Principles for Agent Safety 8
- Shadow AI 8
- Vendor Risks 9
- Monitoring 9
- Incident Response Playbook.....10
- Awareness10
- Maturity Checklist.....11
- Recommendations11
- Next Steps11
- Glossary of Key Terms.....12
- About TSEC & Next Steps12

Executive Summary

Generative AI tools — chat assistants, copilots embedded in productivity software, and increasingly autonomous agents — have moved from experimental to operational faster than most security programs have been able to adapt. Unlike traditional software, large language models (LLMs) process instructions and data through the same channel, which creates security failure modes that conventional application security testing does not cover: prompt injection, unintended data disclosure through model output, and system prompts that can be extracted or manipulated.

This guide translates the OWASP Top 10 for LLM Applications and NIST’s Generative AI Profile (NIST AI 600-1) into practical controls an organization can implement without a dedicated AI security team. It covers data protection, prompt security, identity and access management, agentic AI risk, the growing problem of "shadow AI," vendor risk specific to generative AI, ongoing monitoring, incident response, and employee awareness — the combination of technical and human controls that a defensible GenAI security program requires.

GenAI Risk Overview

NIST AI 600-1 identifies twelve risk categories specific to generative AI, ranging from content risks (harmful or hateful output, misinformation, obscene content) to systemic risks (environmental impact, intellectual property exposure) to the security and privacy risks this guide focuses on: information security, data privacy, and value-chain integrity. Confabulation — the model confidently producing false information — sits alongside these as one of the most consequential risks in domains like healthcare, legal, and financial services, where a plausible-sounding but incorrect answer can cause real harm if not independently verified.

From a security standpoint, the OWASP Top 10 for LLM Applications (2025) provides the most widely referenced risk taxonomy. The table below summarizes the risks most relevant to enterprise deployment; the sections that follow expand on the controls that address them.

OWASP Category	What It Is	Primary Control Area
LLM01 — Prompt Injection	Attacker-crafted input causes the model to follow unintended instructions.	Prompt Security
LLM02 — Sensitive Information Disclosure	Model output reveals private data, credentials, or confidential context.	Data Protection
LLM03 — Supply Chain	Risk introduced through third-party models, plugins, or fine-tuning data.	Vendor Risks
LLM06 — Excessive Agency	An AI agent is granted more autonomy or system access than its task requires.	IAM / Agentic AI
LLM07 — System Prompt Leakage	Internal instructions, rules, or business logic are extracted from the model.	Prompt Security

OWASP Category	What It Is	Primary Control Area
LLM08 — Vector & Embedding Weaknesses	RAG pipelines retrieve or leak data outside the intended scope of a query.	Data Protection
LLM10 — Unbounded Consumption	Uncontrolled cost, compute, or API usage from malicious or runaway activity.	Monitoring

Data Protection

The single highest-leverage control in generative AI security is preventing sensitive data from reaching a model that should not have it — whether through a prompt, an uploaded document, or a retrieval-augmented generation (RAG) pipeline.

Classify Before You Connect

- ☐ Data classification policy explicitly states which categories (PII, PHI, financial account data, source code, trade secrets, unreleased strategic plans) may or may not be submitted to which tiers of AI tool (approved enterprise tools vs. public consumer AI).
- ☐ RAG and knowledge-base integrations are scoped so that the model only retrieves data the requesting user is authorized to see — AI does not bypass existing document permissions.
- ☐ Training and fine-tuning datasets are inventoried, and any personal data included has a documented legal basis.

Securing RAG Pipelines

Retrieval-augmented generation introduces its own attack surface, distinct from the underlying model: OWASP's Vector & Embedding Weaknesses category covers exactly this.

- ☐ Document-level and field-level permissions carry through into the embedding/retrieval layer, not just the original document store.
- ☐ Embeddings derived from sensitive documents are stored with the same access controls as the source documents.
- ☐ Retrieval queries are logged so that an over-broad retrieval (a query returning documents outside the expected scope) can be investigated.
- ☐ Where multiple tenants or customers share a vector store, strict namespace isolation prevents cross-tenant retrieval.

Contain the Blast Radius

- ☐ Enterprise AI tools are configured so that customer or company data is not used to train the vendor's underlying models by default.

- ☐ Prompts, outputs, and logs containing sensitive data have defined retention and deletion schedules.
- ☐ Encryption in transit and at rest applies to any data store supporting an AI feature, consistent with the organization's existing security baseline.
- ☐ Outputs are treated as untrusted until reviewed — a model can be induced to reproduce sensitive data it was never supposed to disclose.

Choosing Between Managed and Self-Hosted Models

A foundational security decision that shapes every control in this guide is whether the organization consumes AI through a managed third-party API, a vendor-embedded feature, or a self-hosted/open-weight model run on infrastructure the organization controls. Each path shifts responsibility differently.

Deployment Model	Security Responsibility	Best Fit
Managed API (e.g., third-party foundation model provider)	Vendor secures the model infrastructure; organization secures its own application layer, prompts, and data handling.	Most organizations — fastest to deploy, least infrastructure burden.
Vendor-Embedded Feature (AI inside existing SaaS)	Vendor secures both the model and the feature; organization's responsibility is largely due diligence and data governance.	Low-to-moderate risk use cases where a dedicated AI vendor relationship is not justified.
Self-Hosted / Open-Weight Model	Organization is responsible for the full stack: model security, infrastructure, access control, and monitoring.	Organizations with strict data residency requirements or specialized compliance needs, and the technical capacity to operate it.

Self-hosting is sometimes assumed to be inherently more secure because data never leaves the organization's environment — but it also means every control in this guide (prompt handling, access management, monitoring, incident response) becomes the organization's responsibility to build and maintain rather than a vendor's. Organizations should make this choice deliberately, based on actual data sensitivity and internal capability, rather than by default.

Prompt Security

Prompt injection is the top-ranked risk in the OWASP LLM Top 10 for a structural reason: LLMs do not reliably distinguish between "instructions from the system" and "data being processed," which means content from an email, a web page, or an uploaded document can override the intended behavior of the application.

Direct vs. Indirect Injection

- Direct injection: a user directly instructs the model to ignore its system prompt or safety guidelines.
- Indirect injection: malicious instructions are embedded in content the model processes on the user's behalf — a webpage the model summarizes, a document it reads, or an email it triages — without the user ever typing the malicious instruction themselves.

Secure Prompt Practices

- ☐ Treat all external content the model processes (documents, web pages, emails, API responses) as untrusted input, not as trusted instructions.
- ☐ Apply the principle of least privilege to what an AI feature is allowed to do in response to processed content — a summarization feature should not also have the ability to send emails or modify records.
- ☐ Avoid relying on the system prompt alone as a security boundary; system prompts can often be leaked or overridden and should not contain the only enforcement of a security-relevant rule.
- ☐ Log and review instances where model behavior diverges from expected patterns, as an indicator of injection attempts.
- ☐ Where the platform supports it, use structured input/output boundaries (separating instructions from data fields) rather than freeform text concatenation.

Identity & Access Management

As generative AI shifts from answering questions to taking actions — sending messages, updating records, executing workflows — AI agents effectively become a new class of identity that must be governed with the same discipline as human users and service accounts.

- ☐ Every AI agent or automation with system access has its own identity, not a shared or overly broad service account.
- ☐ Agent permissions follow least privilege: an agent is scoped to only the systems and actions its task requires.
- ☐ Irreversible or high-impact actions (financial transactions, external communications, record deletion, access changes) require human confirmation before execution ("human-in-the-loop"), consistent with OWASP's Excessive Agency guidance.
- ☐ Credentials used by AI agents are rotated, monitored, and revocable on the same schedule as other privileged access.
- ☐ Multi-factor authentication is required for administrative access to AI platforms, model configuration, and prompt/agent management consoles.

Agentic AI Security

Agentic AI — systems that plan multi-step tasks and invoke tools or APIs autonomously — introduces risk beyond a single-turn chatbot. An agent that can browse the web, call internal APIs, and take action compounds every risk in this guide: a successful prompt injection is no longer just a bad chat response, it can become an unauthorized action.

Design Principles for Agent Safety

1. Scope tool access narrowly. An agent should only be able to call the specific APIs and systems its task requires, not the full range of systems the underlying platform integrates with.
2. Treat every tool call as a potential action with consequences, and require human confirmation for anything irreversible, financially material, or externally visible.
3. Isolate agent execution environments from production systems where possible, so a compromised or misdirected agent cannot directly affect critical infrastructure.
4. Cap agent autonomy with hard limits — maximum number of steps, maximum spend, maximum scope of a single task — so a runaway or manipulated agent fails safely rather than compounding errors indefinitely.
5. Maintain a full audit trail of every tool call an agent makes, including the reasoning or instruction that triggered it, to support incident investigation.

Shadow AI

"Shadow AI" refers to employees using AI tools for work without formal approval or oversight — and it is now one of the most significant sources of unmanaged enterprise risk. Industry research indicates the large majority of organizations have employees using unsanctioned AI tools, that IT teams are typically aware of only a fraction of the AI tools actually in use across the organization, and that organizations with high levels of shadow AI experience materially higher average breach costs than those with strong AI governance in place.

Why Shadow AI Happens

It is rarely malicious. Employees adopt unsanctioned AI tools because they are fast, free, and often more capable than approved alternatives — not because they intend to create risk.

This means the most effective countermeasure is providing a good, approved alternative quickly, not enforcement alone.

- ☐ An approved list of AI tools exists and is communicated clearly to employees, along with a fast path to request evaluation of a new tool.
- ☐ Network and endpoint controls provide visibility into AI tool usage (browser extensions, unsanctioned SaaS sign-ups, API usage) rather than relying on self-reporting alone.
- ☐ The acceptable-use policy explicitly addresses generative AI, including what data categories may never be submitted to a public AI tool.
- ☐ Employees are not penalized for previously undisclosed AI tool use when they come forward during an amnesty or discovery period — this increases voluntary disclosure and improves the inventory faster than enforcement alone.

Vendor Risks

Most organizations encounter generative AI risk first through vendors — an AI feature added to an existing SaaS product, not a model built in-house. Vendor-specific due diligence for generative AI should go beyond a standard security questionnaire.

- ☐ The vendor documents whether customer data or prompts are used to train its models, and by default, does not use them.
- ☐ The vendor can describe what underlying model(s) it uses (including sub-processor models from other AI providers) and how it evaluates changes to those models.
- ☐ The vendor can provide evidence of its own security testing for prompt injection and data leakage, not only a general SOC 2 report.
- ☐ Contract terms address AI-specific obligations: data use restrictions, model change notification, audit rights, and liability allocation for AI-generated errors or harmful output.
- ☐ Critical AI vendors (those affecting fraud detection, compliance screening, credit decisions, or customer communications) receive enhanced due diligence proportional to their impact — see TSEC’s AI Vendor Due Diligence Checklist for a full assessment framework.

Monitoring

Generative AI systems require monitoring disciplines that extend beyond traditional application performance monitoring.

- ☐ Usage, cost, and rate-limit monitoring is in place to detect abuse or runaway consumption (OWASP’s Unbounded Consumption risk).
- ☐ Outputs are sampled and reviewed for policy violations, hallucinated/confabulated content in high-stakes contexts, and signs of successful prompt injection.
- ☐ An incident response procedure explicitly covers AI-specific scenarios: harmful or biased output reaching a customer, sensitive data disclosed through a response, or an agent taking an unauthorized action.
- ☐ Logging captures prompts, retrieved context, and outputs with enough fidelity to reconstruct what happened during an incident, subject to the data retention and privacy controls defined earlier in this guide.

Incident Response Playbook

A generic security incident response plan rarely maps cleanly onto AI-specific failure modes. Extend existing runbooks with the scenarios below.

Scenario	Immediate Response	Follow-Up
Sensitive data appears in model output	Disable the feature or session; identify scope of exposure (who saw it, what data)	Notify affected parties per data breach policy if warranted; review RAG/context scoping
Suspected successful prompt injection	Isolate the affected session/agent; review logs for downstream actions taken	Patch input handling; add detection rule for the injection pattern observed
AI agent takes an unauthorized action	Revoke or pause the agent's credentials immediately; assess impact of the action taken	Add human-confirmation gate for the action type; review agent scope and permissions
Harmful or biased output reaches a customer	Acknowledge and correct with the customer; disable the output path if systemic	Root-cause the output; add to output review sampling; consider vendor escalation
Vendor discloses a model or data-handling change	Assess whether the change affects any Critical/High-tier use case	Re-run risk assessment for affected systems; update vendor risk rating

Awareness

Technical controls alone do not close the gap — employees make dozens of small decisions daily about what to type into an AI tool, and awareness training is where policy becomes behavior.

6. Train employees on what categories of data may never be entered into a public or unapproved AI tool, using concrete examples relevant to their role.
7. Teach recognition of AI-specific social engineering: outputs that sound confident but may be fabricated, and content designed to manipulate AI-assisted workflows (indirect prompt injection).
8. Make the approved-tools list and the request-a-new-tool process easy to find — training is most effective when paired with a legitimate, low-friction alternative to shadow AI.
9. Reinforce that AI-generated output in regulated or high-stakes contexts (legal, financial, clinical, hiring) requires human review before use, not blind trust.
10. Repeat training on a recurring cadence — the AI tool landscape changes quickly enough that a single onboarding session will not stay current.

Maturity Checklist

Use this quick self-check to gauge overall GenAI security posture. Each "no" answer is a candidate for near-term remediation.

- ☐ Do we know every generative AI tool and feature currently in use across the organization?
- ☐ Is sensitive data classified with explicit rules for what may reach an AI tool?
- ☐ Have we tested our AI-powered features for prompt injection specifically, rather than relying on general application security testing?
- ☐ Do our AI agents operate under least-privilege access with human confirmation for high-impact actions?
- ☐ Is there a monitoring and incident response plan that names AI-specific scenarios?
- ☐ Have employees received AI-specific security awareness training in the past twelve months?

Recommendations

For most organizations, the highest-impact sequence is: (1) publish and communicate an acceptable-use policy for generative AI within weeks, not months; (2) gain visibility into actual AI tool usage before assuming the current inventory is complete; (3) apply least-privilege and human-in-the-loop controls to any AI agent capable of taking action, not just to chat interfaces; and (4) fold AI-specific questions into existing vendor risk processes rather than building a parallel program. Security teams that wait for a complete AI governance program before addressing generative AI risk typically fall further behind than those who ship a "good enough" policy quickly and refine it.

Next Steps

Organizations securing generative AI deployments should pair this guide with TSEC's AI Prompt Security Guide for a deeper look at prompt injection defenses, and with the AI Vendor Due Diligence Checklist when evaluating specific GenAI vendors. Where generative AI is used in a system that makes or influences decisions about individuals, complete an AI Risk Assessment before production deployment.

Glossary of Key Terms

Term	Definition
Agentic AI	AI systems capable of planning multi-step tasks and autonomously invoking tools, APIs, or actions.
Excessive Agency	An OWASP risk category describing an AI agent granted more autonomy or access than its task requires.
Fine-Tuning	Additional training applied to a pre-trained model using a narrower, often organization-specific dataset.
Foundation Model	A large, general-purpose AI model (often provided by a third party) used as the base for an application.
Prompt Injection	An attack technique where crafted input causes an AI model to follow unintended instructions.
RAG (Retrieval-Augmented Generation)	A technique where a model retrieves relevant documents at query time to ground its response.
System Prompt	The hidden instructions that define an AI application's intended behavior, separate from user input.

About TSEC & Next Steps

TSEC Risk & Cyber Advisory LLC helps SMBs, SaaS companies, FinTech, healthcare organizations, professional services firms, manufacturers, and government contractors build governance, risk management, and compliance programs that hold up under audit — and under real-world adversarial conditions. Our advisory work spans SOC 2, ISO 27001, NIST CSF, HIPAA, PCI DSS, NYDFS, and emerging AI governance requirements.

This resource is one part of a broader compliance library. Organizations that need help translating a checklist into an operating program — policies, control ownership, evidence collection, board reporting, and audit readiness — typically engage TSEC for structured advisory support rather than building it alone.

Work With TSEC

Book a Strategy Call — a working session to review your current AI governance posture against NIST AI RMF and ISO/IEC 42001, and identify the highest-priority gaps.

Email: Info@tsecgrc.com

Web: www.tsecgrc.com

Visit www.tsecgrc.com/resources for the full compliance resource library

© 2026 TSEC Risk & Cyber Advisory LLC. This resource is provided for general informational and educational purposes and does not constitute legal advice. Organizations should consult qualified legal counsel to assess specific regulatory obligations.